

Policy Deliverable I: Phishing Prevention & Perimeter Defense Policy

Document ID: BEF-POL-SEC-2026-V1.1

Framework Benchmark: NIST Cybersecurity Framework (CSF) 2.0

Effective Date: July 2, 2026

Classification: Internal Use Only

1. Document Overview

1.1 Purpose

The purpose of this policy is to establish baseline defensive controls against electronic messaging threats and social engineering exploits, while mandating core technical perimeters to maintain network-level data encryption and threat monitoring.

1.2 Scope

This policy applies to all personnel (including full-time employees, part-time staff, logisticians, contractors, and third-party vendors) who use BlackSea E-Com Fulfillment (BEF) electronic messaging systems or connect to BEF corporate networks.

2. Technical Infrastructure Mandates (DE.CM-01, PR.DS-01, PR.DS-02)

To achieve robust threat detection and total cryptographic security of corporate data, the information technology infrastructure must natively maintain the following boundaries:

- **Perimeter Firewalls:** Maintained to regulate inbound and outbound connections and drop unauthorized baseline traffic.
- **Intrusion Detection Systems (IDS):** Permanently deployed across internal networks to actively inspect packets and generate immediate security telemetry logs for suspicious or anomalous behavior patterns.
- **Virtual Private Networks (VPN):** Endpoints operating outside the local office perimeter must establish connection via an enterprise-grade VPN tunnel to guarantee end-to-end encryption of data in transit.

3. Messaging Triage & Response Protocols (RS.RP-01)

Personnel must exercise extreme diligence during electronic correspondence. If an inbound message exhibits any suspicious anomalies, the workforce is mandated to follow these explicit procedures:

3.1 Unverified, Unknown, or Unexpected Senders

If an email is unexpected, originates from a sender whom the employee does not know, displays a tone of manufactured urgency, or requests immediate actionable steps (e.g., clicking hyperlinks, downloading unrecognized attachments, or shifting operational workflows), the employee **shall not** interact with the contents. The employee **must** immediately generate an incident ticket with the security triage desk to mark the message for investigation and forensic quarantine.

3.2 Known Senders Exhibiting Red Flags

If an email demands urgent, confidential, or unusual administrative action, but appears to originate from a known internal colleague or established vendor partner, the employee **must** verify the authenticity of the message before interacting with it. Verification must be performed via an alternative, out-of-band communication channel (e.g., a direct phone call, an in-person validation, or an internal chat platform). Employees **shall not** reply directly to the suspicious email thread to verify its legitimacy.

4. Enforcement & Non-Compliance Framework

Violations of this policy will trigger an immediate administrative and forensic review. Disciplinary enforcement is broken down into clear categories based on user intent and history:

Violation Severity Classification	Deterministic Criteria	Prescribed Disciplinary Action
Negligent / Honest Mistake	Inadvertent user interaction with a phishing link due to an oversight, with no intent to cause harm.	First offense: Formal verbal warning and mandatory completion of remedial security awareness training. Subsequent offenses: Escalating administrative fines and written reprimands.
Malicious /	Deliberate circumvention	Immediate termination of

Violation Severity Classification	Deterministic Criteria	Prescribed Disciplinary Action
Intentional Sabotage	of messaging controls, intentional data exfiltration, or collusive insider threat execution.	employment, complete revocation of physical/digital credentials, and immediate referral to law enforcement for criminal prosecution and legal action.